

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

RCE Flaw in WordPress Calendar Plugin Puts 150,000 Sites at Risk

Date of Publication

July 10, 2024

Admiralty Code

A1

TA Number

TA2024266

Summary

First Seen: May 20, 2024
Affected Products: WordPress Modern Events Calendar Plugin
Impact: A security flaw, CVE-2024-5441, has been discovered in the Modern Events Calendar, a widely used WordPress plugin with over 150,000 active installations. Developed by Webnus, this plugin is designed to organize and manage in-person, virtual, or hybrid events. The vulnerability allows attackers to upload arbitrary files to a vulnerable site and execute code remotely, posing a significant risk to the security of the affected websites.

⚙️ CVE

CVE	NAME	AFFECTED PRODUCT	ZERO -DAY	CISA KEV	PATCH
CVE-2024-5441	WordPress Modern Events Calendar Plugin Arbitrary File Upload Vulnerability	Modern Events Calendar, Modern Events Calendar Lite	❌	❌	✅

Vulnerability Details

- #1 Hackers are currently exploiting a vulnerability in the Modern Events Calendar WordPress plugin, which helps manage events both online and offline. This vulnerability, identified as CVE-2024-5441, allows attackers to upload files and execute code remotely, putting over 150,000 websites at risk.
- #2 The issue lies in the plugin's `set\_featured\_image` function, which doesn't properly validate the types of files being uploaded. This oversight means that even users with minimal access, such as subscribers, can upload dangerous files to the server. Consequently, hackers can potentially run malicious code on affected websites. Additionally, the plugin allows administrators to submit events without requiring user authentication, which makes it easier for attackers to exploit this flaw.

#3

The function ``set_featured_image()`` uploads and sets featured images for events and is intended for use by registered users and guests submitting events through the frontend. This function downloads images via the ``get_web_page()`` function and uploads them to the WordPress uploads directory using ``file_put_contents()``. However, the lack of proper file type or extension checks means that attackers can upload harmful files, including those with a ``.php`` extension, leading to remote code execution on the server.

#4

Even unauthenticated attackers can exploit this vulnerability by submitting a malicious PHP file including webshells. Over 100 exploitation attempts have been observed within just 24 hours. Users of the Modern Events Calendar and its Lite version are urged to immediately update to the latest version, 7.12.0, to ensure their websites remain secure.

 Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2024-5441	Modern Event Calendar version 7.11.0 and prior	cpe:2.3:a:modern_events_calendar_plugin:modern_events_calendar_plugin:*:*:*:*:*	CWE-434

Recommendations



Keep Plugins Updated: Ensure that all WordPress plugins, including Modern Events Calendar plugin, are regularly updated to the latest versions to patch known vulnerabilities.



Deploy Behavioral Analysis Solutions: Utilize behavioral analysis solutions to detect any anomalous behavior on systems. Ensure that endpoint protection solutions are regularly updated to identify and mitigate the latest threats.



Implement Web Application Firewall (WAF): Deploy a WAF to monitor and filter incoming web traffic. A properly configured WAF can detect and block attempts to exploit the RCE vulnerability, providing an additional layer of protection.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>T1588</u> Obtain Capabilities
<u>T1588.006</u> Vulnerabilities	<u>T1190</u> Exploit Public-Facing Application	<u>T1059</u> Command and Scripting Interpreter	<u>T1203</u> Exploitation for Client Execution

Patch Details

Website administrators should promptly update the Modern Events Calendar WordPress plugin to version 7.12.0 to ensure that their sites are protected against the vulnerability.

Link: <https://webnus.net/modern-events-calendar/>

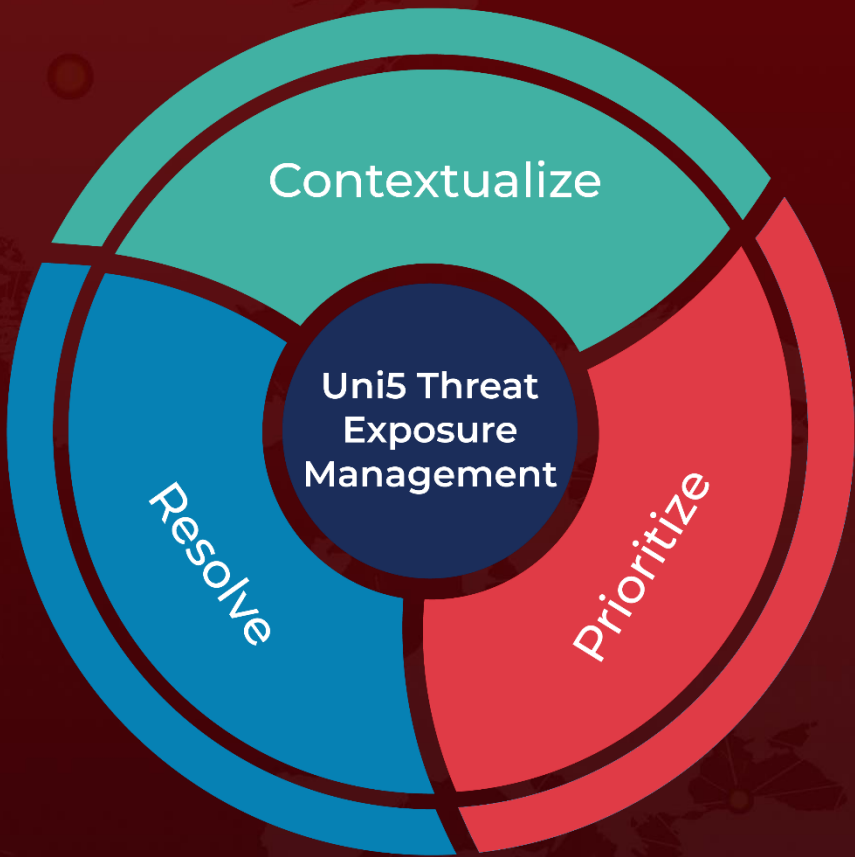
References

<https://www.wordfence.com/blog/2024/07/3094-bounty-awarded-and-150000-wordpress-sites-protected-against-arbitrary-file-upload-vulnerability-patched-in-modern-events-calendar-wordpress-plugin/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
July 10, 2024 • 6:15 AM

